SECCIÓN 5.2

Interpretación de eventos individuales

Temas de esta sección:

- Qué es un evento individual y qué puede (y no puede) decir
- Eventos de proceso, archivo, red, DNS y autenticación
- Diferencia entre evento bloqueado, permitido y registrado
- Por qué un evento único puede ser ambiguo
- La importancia del 'antes y después'
- 10 pasos para analizar un evento individual

5.2 | Qué puede decir un evento individual — y qué no

Un evento SÍ puede decir:

- Qué ocurrió
- Cuándo y en qué host
- Qué proceso participó
- Qué archivo fue creado o modificado
- Qué dominio fue consultado
- Cuál fue la acción del control
- Qué usuario estaba involucrado
- Cuál fue el resultado de la operación

Un evento NO puede confirmar:

- ✘ Intención del usuario
- ✘ Compromiso confirmado
- ✘ C2 confirmado
- ✘ Exfiltración confirmada
- ✘ Impacto real
- ✘ Alcance completo
- ✘ Si la acción fue maliciosa
- ✘ El contexto operativo (cambio, ticket)

Los eventos son piezas. El análisis es el armado de esas piezas para construir contexto y tomar decisiones.

5.2 | Tipos de eventos y qué mirar en cada uno

Cinco tipos de eventos frecuentes en SOC y sus campos más importantes:

		⚠
PROCESO	Proceso · Proceso padre · Línea de comandos · Ruta · Usuario · Host · Hora · Procesos hijos · Acción	*PowerShell no es malicioso solo. Mirá el padre y los parámetros.*
ARCHIVO	Nombre · Ruta · Proceso que lo creó · Hash · Firma · Hora · Acción · Si fue ejecutado después	*Archivo en AppData/Public no confirma malware. Combinado con ejecución y red, cambia.*
RED	Host · Usuario · Proceso · IP/Dominio destino · Puerto · Acción · Volumen · Frecuencia	*Conexión permitida ≠ actividad legítima. Bloqueada ≠ caso cerrado.*
DNS	Host · Dominio consultado · Tipo · Respuesta · Código · Frecuencia · Conexión posterior	*Consulta DNS ≠ conexión exitosa. Solo indica que se intentó resolver.*
AUTENTICACIÓN	Usuario · Resultado · IP · Ubicación · Dispositivo · MFA · Aplicación · Actividad posterior	*Login exitoso ≠ login legítimo. MFA exitoso ≠ no hay compromiso.*

5.2 | Bloqueado, permitido y registrado: qué implica cada uno

La acción del control es uno de los campos más malinterpretados en SOC:

BLOCKED / Bloqueado

El control actuó e impidió la acción.

✔️ Reduce el riesgo inmediato.

✘ NO cierra automáticamente el caso:
- ¿Hubo ejecución previa al bloqueo?
- ¿El payload ya fue descargado?
- ¿Hay persistencia activa?
- ¿Otros hosts tienen el mismo indicador?

Documentar y revisar actividad previa.

ALLOWED / Permitido

El control no actuó. La acción se completó.

⚠ Requiere análisis completo:
- ¿Era la acción esperada?
- ¿Hubo actividad posterior?
- ¿El proceso tiene contexto operativo?
- ¿El destino es conocido y legítimo?

Allowed no es sinónimo de legítimo.

LOGGED / Registrado

El control solo registró. No actuó.

⚠ Solo tenemos visibilidad:
- No hay bloqueo ni permiso activo
- La acción puede haber ocurrido
- La fuente puede tener modo audit-only
- El WAF en Alert Only cae aquí

Lo más crítico: WAF Alert Only + EDR muestra ejecución real → escalar.

5.2 | Evento único vs patrón: la diferencia clave

Un evento aislado puede ser ambiguo. Un patrón cambia completamente el análisis:

EVENTO ÚNICO	PATRÓN	EVENTO ÚNICO	PATRÓN

`One failed login`	`300 failed logins`
	`+ 1 successful login`
	`+ New device`
	`+ Mailbox rule created`
		`One DNS query to rare domain`	`DNS query + Network connection`
			`+ File downloaded`
			`+ Scheduled task created`
			`+ Beaconing every 60s`

Error de usuario	*Posible ataque de fuerza bruta con compromiso posterior*	*Ruido o navegación*	*Posible cadena de ejecución inicial y persistencia*

El SOC debe buscar patrones, no solo eventos aislados. La importancia del 'antes y después' es fundamental para interpretar cualquier evento.

5.2 | 10 pasos para analizar un evento individual

Una secuencia repetible que aplica a cualquier tipo de evento:

1

¿Qué herramienta generó la alerta?

Conocer la fuente define qué puede y qué no puede decir el dato.

2

¿Qué evento disparó la alerta?

El nombre de la alerta orienta, pero el evento crudo es la evidencia real.

3

¿Cuál fue la acción del control?

Allowed, Blocked o Logged cambian completamente el análisis posterior.

4

¿Quién y dónde?

Usuario, host, activo crítico o no, rol técnico o no.

5

¿Cuándo?

Horario, dentro o fuera de ventanas, coincidencia con cambio.

6

¿Proceso padre y línea de comandos?

El campo más importante en alertas de endpoint.

7

¿Qué pasó antes?

Buscar actividad previa relacionada en el mismo host o usuario.

8

¿Qué pasó después?

Actividad posterior puede confirmar o descartar hipótesis.

9

¿Hay otros hosts o cuentas afectados?

El alcance define la urgencia y el tipo de escalamiento.

10

¿Qué hipótesis tengo y qué me falta?

Documentar la certeza actual y las limitaciones de visibilidad.